Day36_ErrorHandling.

Q1 — Exceptional Conditions [2 Marks]

What is an exceptional condition? Give four examples.

An exceptional condition is an unexpected situation that interrupts the normal execution of an application.

Four examples are:

- Database connection failure.
- Invalid user input.
- File not found error.
- Network connection timeout.

Q2 — Fail Open vs Fail Closed [3 Marks]

Explain the difference between Fail Open and Fail Closed / Fail Secure. Give one security example.

- **Fail Open:** When a system encounters an error, it allows access or continues operating without enforcing the security restriction.
- **Fail Closed / Fail Secure:** When a system encounters an error, it denies access or blocks the operation to maintain security.

Example: If an authentication service becomes unavailable, a fail-open system might allow access without verification, while a fail-closed system denies access until authentication is available.

Q3 — Error Information Disclosure [3 Marks]

Explain why verbose error messages and stack traces may create security risk. List four examples of information that should not normally be exposed to users.

Verbose error messages and stack traces can expose internal application details that attackers may use to identify vulnerabilities and plan attacks.

Four examples :

- Database connection details.
- Internal file paths.
- Software framework and version information.
- Stack traces and internal code details.

Day36_ErrorHandling.

Q4 — Transactions [2 Marks]

Explain why rollback is important when a multi-step transaction fails.

Rollback is important because it reverses incomplete changes when a multi-step transaction fails. It helps maintain database consistency and prevents incomplete or incorrect data from being saved.

Example: If a money transfer fails halfway through, rollback ensures that the transaction does not leave the account balances inconsistent.

Q5 — Resource Handling [2 Marks]

Explain how poor resource cleanup during repeated exceptions may affect application availability.

Poor resource cleanup during repeated exceptions can cause memory leaks, excessive CPU usage and exhausted database connections. This can slow down the application, make it unstable or eventually cause a service outage. Applications should properly release resources such as memory, files and database connections after errors.

Q6 — Secure Error Design [3 Marks]

Write at least six recommendations for secure exception/error handling.

Six recommendations for secure exception and error handling are:

1) Display generic error messages to users.
2) Avoid exposing stack traces and internal technical details.
3) Validate user input before processing it.
4) Store detailed error information in protected internal logs.
5) Use proper exception handling to prevent unexpected application crashes.
6) Release resources properly after exceptions.
7) Use fail-secure behaviour for security-sensitive operations.

Q7 — Practical Lab [3 Marks]

Explain what information was disclosed in the Day 36 PortSwigger lab. Attach evidence and explain how it should be fixed.

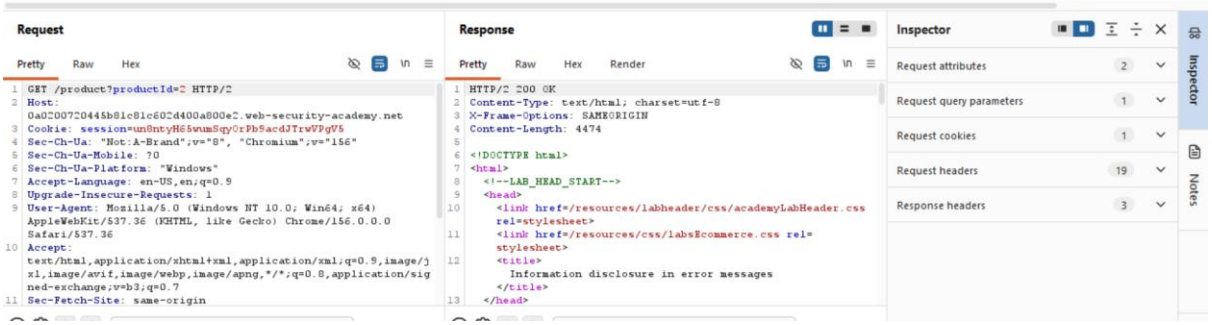
- ✓ Display generic error messages to users instead of detailed technical errors.
- ✓ Disable debug mode in production environments.
- ✓ Validate and sanitize user input before processing requests.
- ✓ Store detailed stack traces and error information in protected server-side logs.
- ✓ Keep application frameworks and software dependencies updated.
- ✓ Implement proper exception handling to prevent internal information disclosure.

Day36_ErrorHandling.

Evidences:



36	https://0a0200720445b81c8...	GET	/product?productId=2	✓	200	4582	HTML	Information disclosur...	✓	79.125.84.16
37	https://0a0200720445b81c8...	GET	/academyLabHeader		101	147			✓	79.125.84.16



Request

Pretty Raw Hex

```
1 GET /product?productId=2 HTTP/2
2 Host:
  0a0200720445b81c81c602d400a800e2.web-security-academy.net
3 Cookie: session=un8ntyH65wumSqy0rPb9acdJTrwVPgV5
4 Sec-Ch-Ua: "Not:A-Brand";v="8", "Chromium";v="156"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: en-US,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/156.0.0.0
  Safari/537.36
10 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/j
  xl,image/avif,image/webp,image/apng,*/*;q=0.8,application/sig
  ned-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
```

Response

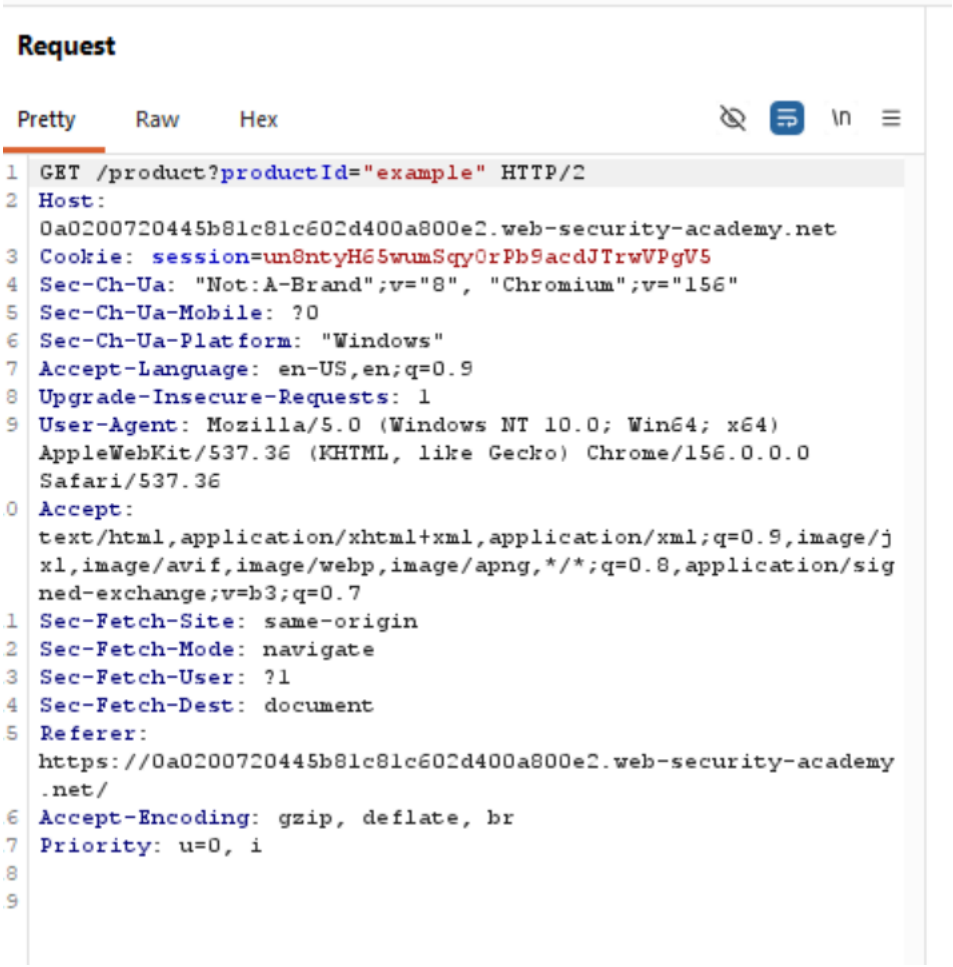
Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 4474
5
6 <!DOCTYPE html>
7 <html>
8   <!--LAB_HEAD_START-->
9   <head>
10    <link href=/resources/labheader/css/academyLabHeader.css
      rel=stylesheet>
11    <link href=/resources/css/labsEcommerce.css rel=
      stylesheet>
12    <title>
        Information disclosure in error messages
      </title>
13  </head>
```

Inspector

- Request attributes 2
- Request query parameters 1
- Request cookies 1
- Request headers 19
- Response headers 3

Inspector Notes

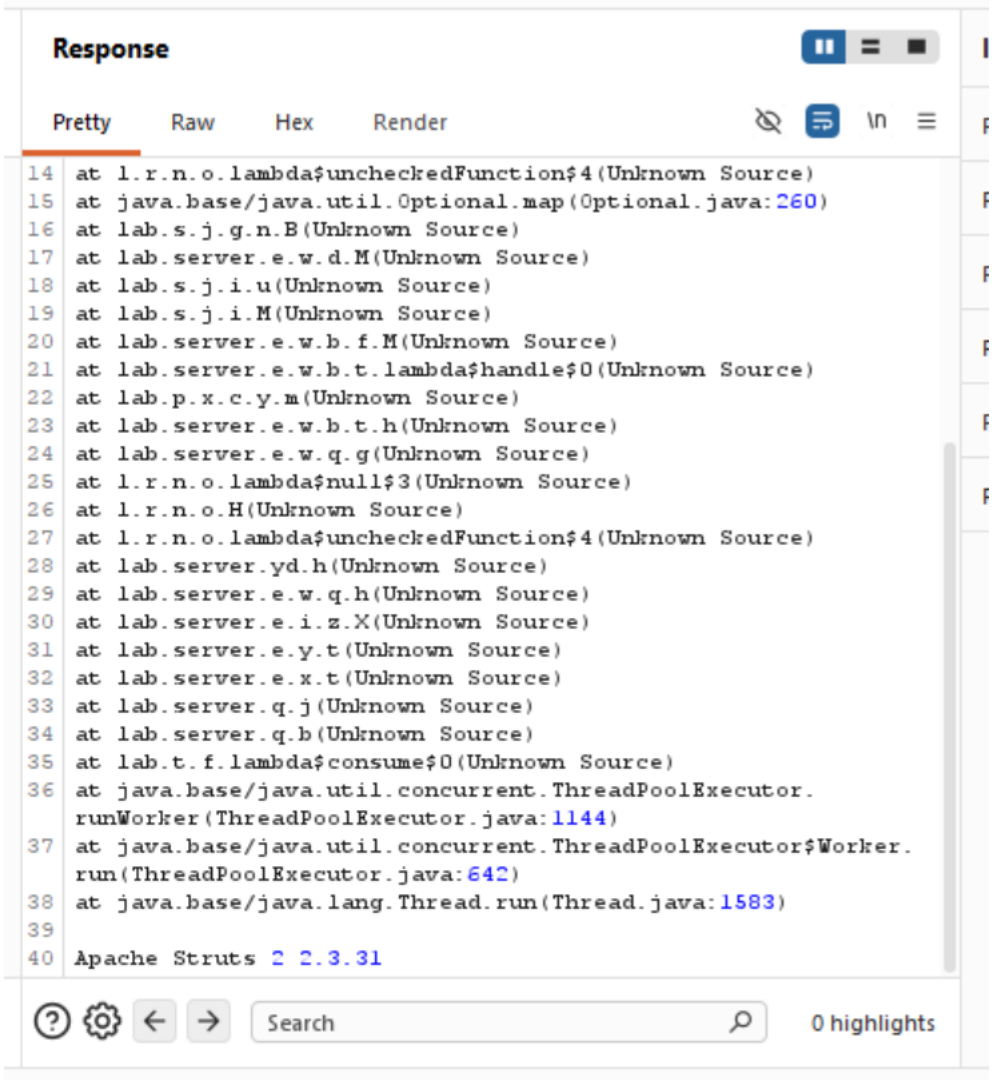


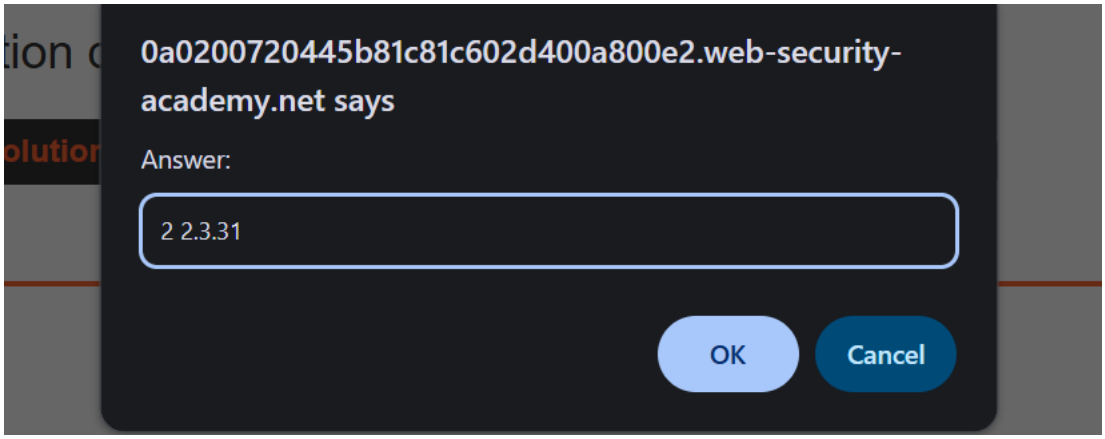
Request

Pretty Raw Hex

```
1 GET /product?productId="example" HTTP/2
2 Host:
  0a0200720445b81c81c602d400a800e2.web-security-academy.net
3 Cookie: session=un8ntyH65wumSqy0rPb9acdJTrwVPgV5
4 Sec-Ch-Ua: "Not:A-Brand";v="8", "Chromium";v="156"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Accept-Language: en-US,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/156.0.0.0
  Safari/537.36
0 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/j
  xl,image/avif,image/webp,image/apng,*/*;q=0.8,application/sig
  ned-exchange;v=b3;q=0.7
1 Sec-Fetch-Site: same-origin
2 Sec-Fetch-Mode: navigate
3 Sec-Fetch-User: ?1
4 Sec-Fetch-Dest: document
5 Referer:
  https://0a0200720445b81c81c602d400a800e2.web-security-academy
  .net/
6 Accept-Encoding: gzip, deflate, br
7 Priority: u=0, i
8
9
```

Day36_ErrorHandling.







Day36_ErrorHandling.

Q8 — Jayvik Portal Scenario [2 Marks]

Imagine the Jayvik Labs Student Portal database temporarily becomes unavailable. Describe how the student-facing application should respond securely.

- ✓ Display a generic message such as: "The service is temporarily unavailable. Please try again later."
- ✓ Avoid exposing database errors, connection strings or stack traces to students.
- ✓ Log detailed technical information securely for administrators and developers.
- ✓ Deny sensitive operations until the database connection is restored.
- ✓ Retry the connection safely without creating duplicate transactions or data.